

BONUS 2 U3_S11_L5

D: Quali sono i due indirizzi IP coinvolti in questo attacco di SQL injection in base alle informazioni visualizzate?

R: 10.0.2.4, 10.0.2.15

D: Qual è la versione?

R: 5.7.12

D: Cosa farebbe per l'aggressore il comando modificato di (1' OR 1=1 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users')?

R: Grazie a questo passaggio di ricognizione (enumeration), l'aggressore scopre la struttura esatta della tabella. Una volta identificati i nomi delle colonne (come ad esempio username, password, email, hash_password), potrà eseguire un secondo attacco mirato per esfiltrare i dati riservati contenuti in quelle colonne specifiche.

D: Quale utente ha l'hash della password di 8d3533d75ae2c3966d7e0d4fcc69216b?

R: 1337

D: Qual è la password in chiaro?

R: Charley

D: 1. Qual è il rischio che le piattaforme utilizzino il linguaggio SQL? I siti web sono comunemente basati su database e utilizzano il linguaggio SQL. La gravità di un attacco di SQL injection dipende dall'aggressore.

R: Il rischio legato all'uso del linguaggio SQL e la gravità di un attacco

I database relational basati su SQL rappresentano la spina dorsale di gran parte dei siti e delle applicazioni web, conservando dati critici come credenziali di accesso, informazioni personali (PII), transazioni finanziarie e configurazioni di sistema.

Il rischio principale risiede nel fatto che, se l'applicazione non gestisce correttamente gli input forniti dagli utenti (come moduli di login, barre di ricerca o parametri negli URL), un attaccante può iniettare istruzioni SQL malevole. L'applicazione interpreta l'input manipolato non come un dato semplice, ma come parte del comando da eseguire nel database.

La gravità di un attacco SQL Injection (SQLi) dipende dalle intenzioni e dall'abilità dell'aggressore, consentendogli di:

Bypassare l'autenticazione: Accedere ad aree riservate o con privilegi da amministratore senza credenziali valide.
Esfiltrare dati sensibili (Sottrazione di dati): Leggere informazioni riservate, tabelle clienti o password memorizzate nel database.

Manomettere o distruggere i dati: Modificare, cancellare o corrompere intere tabelle del database (es. comandi DROP TABLE o DELETE).

Eseguire comandi di sistema: Nei casi più gravi, prendere il controllo completo del server su cui risiede il database.

D: 2. Naviga in internet ed esegui una ricerca per “prevenire attacchi di SQL injection”. Quali sono 2 metodi o passaggi che possono essere adottati per prevenire gli attacchi di SQL injection? Le risposte varieranno, ma dovrebbero includere: filtrare l'input dell'utente, implementare un firewall per applicazioni web, disabilitare funzionalità/capacità non necessarie del database, monitorare le istruzioni SQL, utilizzare parametri con stored procedure e utilizzare parametri con SQL dinamico.

R: Metodi e passaggi per prevenire gli attacchi di SQL Injection

Per mitigare e prevenire efficacemente gli attacchi di SQL Injection, è possibile adottare diversi metodi e best practice di sicurezza:

Uso di query parametrizzate / Istruzioni preparate (Prepared Statements) e Stored Procedure:

Istruzioni preparate / Parametri con SQL dinamico: Separano nettamente il codice SQL dai dati inseriti dall'utente.

Il motore del database tratta sempre l'input dell'utente come un valore letterale (dato) e mai come codice eseguibile, rendendo inoffensiva qualsiasi istruzione SQL iniettata.

Stored Procedure: Utilizzare procedure memorizzate nel database con parametri ben definiti impedisce all'utente di formare ed eseguire direttamente comandi non autorizzati.

Filtrare, convalidare e sanificare l'input dell'utente (Input Sanitization & Validation):

Verificare rigorosamente i dati forniti dall'utente prima che vengano elaborati dal sistema (es. consentire solo numeri per campi ID, applicare whitelist di caratteri ammessi ed eseguire l'escape dei caratteri speciali).

Implementare un Web Application Firewall (WAF):

Un WAF analizza il traffico HTTP in ingresso verso la piattaforma e blocca automaticamente le richieste che contengono pattern o firme riconducibili ad attacchi SQL injection.

Principio del minimo privilegio e disabilitazione delle funzionalità non necessarie:

Limitare i permessi dell'account con cui l'applicazione si connette al database al minimo indispensabile.

Disabilitare funzionalità o estensioni del database non strettamente necessarie (es. l'esecuzione di comandi di sistema operativo via database) per ridurre la superficie di attacco.

Monitorare e analizzare le istruzioni SQL:

Implementare strumenti di audit, tracciamento e monitoraggio dei log per identificare anomalie nelle query, tentativi frequenti di erogazione di errori SQL o comportamenti sospetti in tempo reale.